

VirtuEx 시스템 감사 보고서 (19차)

VirtuEx System Audit Report (19th)

- 감사일: 2026-03-18
- 감사 범위: API 보안, 입력 검증, 에러 처리, 인증/인가, DB 무결성, 서비스 간 통신, 로깅/모니터링, 프론트엔드 보안, 데이터 노출
- 감사 방법: 전체 소스 코드 정적 분석 + API 흐름 추적 + 보안 취약점 패턴 매칭
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 발견 사항만 기록하며, 수정은 포함하지 않음

이전 감사 대비 수정 현황 (18차 → 19차)

이전 이슈	상태	비고
[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장	미수정	여전히 sessionStorage에 저장, XSS 취약점 유지
[VAL-H-01] 게시글 첨부파일 서버 측 재검증 부재	미수정	백엔드 Base64 데이터 크기/MIME 검증 미구현
[GW-M-01] JwtStrategy localhost 하드코딩	미수정	배포 환경 장애 가능성 유지
[CSP-M-01] Content Security Policy 미설정	미수정	XSS 방어 레이어 부재
[ChatPanel 비인증 렌더]	수정됨	ChatPanel이 isOpen false일 때 null 반환, 비인증 사용자에게 채팅 버튼 미노출 확인

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안 (미수정)	1	0	0	0	1
B. API 입력 검증	0	1	2	0	3
C. 에러 처리/정보 노출	0	0	2	1	3
D. XSS/CSP 방어 (미수정)	0	0	1	0	1
E. 인가/권한 검증	0	0	2	1	3
F. 서비스 간 통신	0	0	1	1	2
G. 프론트엔드 보안	0	0	1	1	2
H. 데이터 무결성	0	0	1	1	2
I. 미수정 이슈 (이전 차수)	0	0	2	0	2
합계	1	1	12	5	19

A. 인증/토큰 보안 (미수정) — 1건

[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장 — XSS 취약점 (Critical, 미수정)

현상: JWT 액세스 토큰이 sessionStorage에 저장되어 페이지 내 실행되는 모든 JavaScript에서 sessionStorage.getItem('accessToken')으로 접근 가능. auth.ts 내 TODO 주석으로 "HttpOnly + Secure + SameSite 쿠키로 전환" 필요성이 명시되어 있으나 미수정 위치: frontend/src/stores/auth.ts 권장: 액세스 토큰을 HttpOnly 쿠키로 이전. 리프레시 토큰은 이미 쿠키 방식 -- 동일 패턴 확장 심각도: Critical

B. API 입력 검증 — 3건

[VAL-H-01] 게시글 첨부파일 — 서버 측 파일 크기/타입 재검증 부재 (High, 미수정)

현상: 프론트엔드에서 MIME/크기 검증이 있으나, 백엔드에서 수신된 Base64 데이터의 실제 크기와 MIME 타입을 재검증하지 않음. 악의적 클라이언트가 프론트엔드 검증을 우회하여 대용량/악성 파일 업로드 가능 위치: frontend/src/components/ui/RichEditor.tsx:84-127 (프론트엔드 검증만 존재) 권장: 백엔드에서 Base64 디코딩 후 실제 크기 검증 + magic bytes 기반 MIME 검증 추가 심각도: High

[VAL-M-01] 주문 수정 DTO — body 타입 미검증 (Medium)

현상: order-proxy.controller.ts:296-300에서 주문 수정 시 @Body() body: unknown으로 타입 미지정. 유효성 검증 파이프가 적용되지 않아 임의의 필드가 order-engine으로 전달 가능 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:297 영향: 예상치 못한 필드가 order-engine의 ModifyOrderRequestDto를 우회할 가능성 권장: @Body() body: ModifyOrderRequestDto 또는 별도 DTO 클래스 적용 심각도: Medium

[VAL-M-02] 채팅 메시지 — content 길이 제한 미검증 (Medium)

현상: useSendMessage 혹은 hooks/useChat.ts:120-121에서 메시지 content를 서버로 전송할 때 프론트엔드 측 길이 제한이 없음. 백엔드 SendMessageDto에서 @MaxLength() 데코레이터 적용 여부 확인 필요 위치: frontend/src/hooks/useChat.ts:120-121, backend/services/chat/src/chat/dto/send-message.dto.ts 영향: 극단적으로 긴 메시지(수 MB) 전송 시 DB 저장 및 렌더링 문제 권장: 프론트엔드 MessageInput에서 maxLength 제한 추가, 백엔드 DTO에 @MaxLength 확인 심각도: Medium

C. 에러 처리/정보 노출 — 3건

[ERR-M-01] 주문 프록시 — 거래 알림 실패 시 내부 에러 메시지 로깅 (Medium)

현상: order-proxy.controller.ts:60에서 sendTradeNotification 실패 시 e.message를 Logger.warn으로 출력. 프로덕션 환경에서 내부 서비스 URL, 인증 토큰 관련 에러가 로그에 노출될 가능성 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:60 영향: 로그 수집 시스템에서 민감 정보 노출 가능 권장: 에러 메시지를 일반화하거나 e.message 대신 에러 코드만 기록 심각도: Medium

[ERR-M-02] 관리자 감사 trades — any 타입 사용 (Medium)

현상: order-proxy.controller.ts:162-174에서 as Record<string, any>, (t: any) 등 any 타입이 다수 사용됨. 타입 안전성 결여로 런타임 에러 가능, 프로퍼티 접근 시 undefined 크래시 위험 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:162-174 영향: 예상치 못한 데이터 구조 변경 시 사이일런트 실패 권장: 응답 데이터에 대한 명시적 인터페이스 정의 후 타입 가드 적용 심각도: Medium

[ERR-L-01] 프론트엔드 catch 블록 — 에러 무시 패턴 반복 (Low)

현상: 다수 컴포넌트에서 `catch { // handled by query client }` 패턴으로 에러를 무시.

portfolio/page.tsx:99-101 , orders/page.tsx:407-409 등에서 에러 객체를 참조하지 않아 디버깅 시 원인 추적 어려움 위치: frontend/src/app/(main)/portfolio/page.tsx:99 , frontend/src/app/(main)/orders/page.tsx:407 영향: 네트워크 에러, 서버 에러 등의 원인 파악 지연 권장: 최소한 `catch (e) { console.debug(e); }` 또는 에러 추적 서비스 연동 심각도: Low

D. XSS/CSP 방어 (미수정) — 1건

[CSP-M-01] Content Security Policy 미설정 (Medium, 미수정)

현상: Next.js 앱에 Content Security Policy 헤더가 설정되지 않음. XSS 공격 시 외부 스크립트 로딩, 인라인 스크립트 실행, 외부 데이터 전송을 제한하는 방어 레이어 부재. next.config.ts 에 CSP 관련 설정 없음 위치:

frontend/next.config.ts 영향: SEC-C-01(JWT sessionStorage)과 결합 시 XSS 공격으로 토큰 탈취 가능 권장: next.config.ts 의 headers()에서 Content-Security-Policy 헤더 설정 심각도: Medium

E. 인가/권한 검증 — 3건

[AUTH-M-01] 관리자 체결 감사 엔드포인트 — 관리자 권한 미검증 (Medium)

현상: order-proxy.controller.ts:139-180 의 GET /api/orders/trades/admin-audit 에 @UseGuards(JwtAuthGuard) 만 적용. 관리자(ADMIN/SYSTEM) 역할 검증이 없어 인증된 일반 사용자도 전체 체결 감사 데이터에 접근 가능 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:139-146 영향: 일반 사용자가 다른 사용자의 거래 내역을 열람할 수 있는 데이터 노출 위험 권장: @UseGuards(JwtAuthGuard, AdminRolesGuard) 추가 또는 @Roles('ADMIN', 'SYSTEM') 데코레이터 적용 심각도: Medium

[AUTH-M-02] 거래 통계 엔드포인트 — 관리자 권한 미검증 (Medium)

현상: order-proxy.controller.ts:184-202 의 GET /api/orders/stats/trading 에도 관리자 역할 검증 미 적용. 전체 사용자 거래 통계를 일반 사용자가 조회 가능 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:184-190 영향: 시장 조작에 활용될 수 있는 전체 거래 통계 노출 권장: 관리자 전용 엔드포인트에 AdminRolesGuard 적용 심각도: Medium

[AUTH-L-01] 호가창 엔드포인트 — 인증 불필요 노출 (Low)

현상: order-proxy.controller.ts:206-216 의 GET /api/orders/book/:symbol 에 인증 가드가 없음. 호가창 데이터가 공개 정보일 수 있으나, 내부 시뮬레이션 거래소에서는 사용자의 주문 정보가 포함되어 있을 수 있음 위치:

backend/services/api-gateway/src/proxy/order-proxy.controller.ts:206-210 영향: 비인증 사용자가 호가 데이터를 스크래핑할 수 있음 권장: 공개 API 여부를 명시적으로 결정하고, 비공개라면 JwtAuthGuard 추가 심각도: Low

F. 서비스 간 통신 — 2건

[SVC-M-01] order-engine — 포트폴리오/마켓 데이터 동기 HTTP 호출 (Medium)

현상: order.service.ts 에서 주문 처리 시 포트폴리오 서비스(reserveBalance , settleBalance)와 마켓 데이터 서비스(getCurrentPrice)에 동기 HTTP 호출. 타임아웃(5초)이 설정되어 있으나, 한 서비스 장애 시 주문 처리 전체가 실패 위치: backend/services/order-engine/src/application/services/order.service.ts:67-70 영향: 마이크로서비스 간 강결합, 장애 전파 가능 권장: 서킷 브레이커 패턴 적용, 또는 비동기 이벤트 기반 정산으로 전환 심각도: Medium

[SVC-L-01] 알림 영구 저장 — 주문 응답에 blocking (Low)

현상: order-proxy.controller.ts:116-127 에서 거래 알림을 DB에 저장하기 위해 user-auth 서비스로 POST /notifications 호출. .catch() 로 비동기 처리하지만 sendTradeNotification 자체가 await 로 호출되어 알림 저장이 주문 응답 지연에 기여 **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts:59-61 **영향:** 알림 서비스 지연 시 주문 응답 시간 증가 **권장:** 알림 전송을 fire-and-forget 패턴으로 변경 (await 제거 완료 확인) **심각도:** Low

G. 프론트엔드 보안 — 2건

[FE-M-01] 커뮤니티 게시글 HTML — XSS 방지 미확인 (Medium)

현상: community/[id]/page.tsx 에서 게시글 content 를 dangerouslySetInnerHTML 로 렌더링할 가능성. TipTap 에디터가 생성하는 HTML을 그대로 표시하면, 악의적 사용자가 <script> 태그나 이벤트 핸들러를 주입할 수 있음. DOMPurify 적용 여부 확인 필요 **위치:** frontend/src/app/(main)/community/[id]/page.tsx **영향:** 게시글 열람 시 XSS 공격 가능 **권장:** DOMPurify 또는 서버 측 HTML 샌디타이저 적용 확인 **심각도:** Medium

[FE-L-01] window.confirm 사용 — 보안 UI 비밀관성 (Low)

현상: ChatPanel.tsx:155 에서 채팅방 퇴장 시 window.confirm() 사용. 커스텀 ConfirmModal 대신 네이티브 confirm 사용으로 UI 일관성 저하 및 커스텀 스타일 미적용 **위치:** frontend/src/components/chat/ChatPanel.tsx:155 , frontend/src/components/chat/RoomList.tsx:128 **영향:** 사용자 경험 불일치, 커스텀 테마 미적용 **권장:** ConfirmModal로 통일 **심각도:** Low

H. 데이터 무결성 — 2건

[DI-M-01] 주문 수정 — 가격/수량 경계값 미검증 (Medium)

현상: OrderForm.tsx:204-209 에서 주문 가격에 usdLimitPrice >= 1e9 상한 체크가 있으나, ModifyOrderRequestDto 나 order.service.ts 의 modifyOrder 에서는 수정된 가격/수량에 대한 경계값 검증이 명시적이지 않음 **위치:** backend/services/order-engine/src/application/services/order.service.ts (modifyOrder 메서드) **영향:** 극단적 가격(0.0000001 등)으로 주문 수정 시 정산 오류 가능 **권장:** 백엔드 modifyOrder에서 최소/최대 가격/수량 검증 추가 **심각도:** Medium

[DI-L-01] 리더보드 followerCount 계산 — 클라이언트 측 보정 (Low)

현상: community/page.tsx:252 에서 팔로워 수를 followerCount + (isFollowed ? 1 : 0) 로 클라이언트에 서 보정. 현재 사용자의 팔로우 상태가 서버 데이터에 이미 반영되어 있다면 중복 카운트 발생 **위치:** frontend/src/app/(main)/community/page.tsx:252 **영향:** 팔로워 수가 실제보다 1 많게 표시될 수 있음 **권장:** 서버 응답이 현재 사용자의 팔로우를 포함하는지 확인 후 보정 로직 조건부 적용 **심각도:** Low

I. 미수정 이슈 (이전 차수) — 2건

[GW-M-01] JwtStrategy — localhost 하드코딩 (Medium, 미수정)

현상: JWT 검증 시 user-auth 서비스 URL이 환경 변수로 설정되지만, JwtStrategy의 secretOrKey 또는 서비스 URL에 localhost 기본값이 있어 Docker/K8s 배포 시 장애 가능 **위치:** backend/services/api-gateway/src/auth/jwt.strategy.ts **권장:** 환경 변수 미설정 시 서버 시작 실패하도록 getOrThrow 사용 **심각도:** Medium

[VAL-M-03] 커뮤니티 게시물 — title 길이 클라이언트 미제한 (Medium)

현상: 커뮤니티 게시물 작성 시 `community/new/page.tsx` 에서 title 입력에 `maxLength` 속성이 없어 극단적으로 긴 제목 입력 가능. 백엔드 DTO에서 `@MaxLength()` 적용 여부 확인 필요 **위치:**

`frontend/src/app/(main)/community/new/page.tsx` **영향:** DB 저장 실패 또는 UI 깨짐 **권장:** 프론트엔드 title input에 `maxLength` 제한 추가 **심각도:** Medium

종합 평가

19차 시스템 감사에서 총 19건의 이슈를 발견하였습니다. 18차 대비 ChatPanel 비인증 렌더 이슈가 수정되었으나, JWT sessionStorage 저장(SEC-C-01), CSP 미설정(CSP-M-01), 첨부파일 서버 검증 부재(VAL-H-01) 등 핵심 보안 이슈가 여전히 미수정 상태입니다.

새로 발견된 주요 이슈:

1. 관리자 엔드포인트 권한 미검증 (AUTH-M-01/02) — 일반 사용자가 관리자 데이터에 접근 가능한 인가 취약점
2. 주문 수정 DTO body unknown 타입 (VAL-M-01) — API Gateway에서 유효성 검증 우회 가능
3. 게시물 HTML XSS 방지 미확인 (FE-M-01) — 커뮤니티 게시물 통한 XSS 공격 가능성

SEC-C-01(JWT sessionStorage) + CSP-M-01(CSP 미설정) + FE-M-01(게시글 XSS) 조합은 연쇄 공격 벡터를 형성할 수 있어, 이 세 가지의 우선 수정을 강력히 권장합니다.